



FedRAMP[®] Security Assessment Report (SAR)

for Marcus

T-Pot O&G Threat Intelligence Honeypot Lab

Version 1.0

08/12/2026



info@fedramp.gov

fedramp.gov

Prepared by

Identification of Organization that Prepared this Document	
Organization Name	Marcus (Independent Researcher)
Street Address	N/A — personal lab, address withheld
Suite/Room/Building	N/A
City, State Zip	N/A

Prepared for

Identification of Cloud Service Provider	
Organization Name	N/A — self-directed personal research project; no specific CSP customer organization.
Street Address	N/A — personal lab, address withheld
Suite/Room/Building	N/A
City, State Zip	N/A

Document Revision History

Date	Description	Version	Author
08/12/2026	Initial publication	1.0	Marcus

TABLE OF CONTENTS

1	Introduction.....	6
1.1	About This Document.....	6
1.2	Who Should Use This Document?.....	6
2	Executive Summary.....	7
2.1	Purpose.....	14
2.2	Applicable Laws, Regulations, Standards, and Guidance.....	14
2.3	Scope.....	14
2.3.1	Controls Assessed.....	15
3	System Overview.....	15
3.1	System Description.....	15
4	Assessment Methodology.....	15
4.1	Deviations from the SAP.....	16
4.2	The SRTM.....	16
4.3	Consideration of Threats.....	16
4.4	Document Results.....	17
5	Risks Known for Interconnected Systems and External Services.....	18
	Appendix A Risk Exposure Table.....	20
	Appendix B Security Requirements Traceability Matrix (SRTM) Workbook.....	20
	Appendix C Vulnerability Scan Results.....	20
	Appendix D Documentation Review Findings.....	31
	Appendix E Auxiliary Documents.....	31
	Appendix F Penetration Test Report.....	32

1 Introduction

1.1 About This Document

This Security Assessment Report (SAR) documents the results of the security control assessment performed against the T-Pot O&G Threat Intelligence Honeypot Lab, per the methodology defined in the accompanying Security Assessment Plan (SAP). It should be read together with the System Security Plan (SSP) and SAP for this system.

1.2 Who Should Use This Document?

This document is intended for the system owner (for POA&M tracking and remediation decisions) and for any reviewer evaluating this portfolio project's RMF documentation practice.

2 Executive Summary

This is an initial assessment SAR for the T-Pot O&G Threat Intelligence Honeypot Lab, prepared following the methodology in the accompanying SAP. This report aggregates the results of the OpenSCAP CIS Level 2 configuration scan, the Nessus credentialed vulnerability scan, and manual control examination described in Section 3.

A detailed, itemized risk summary (by category and severity, as this template's standard risk-count table would show) is not reproduced here as a numeric table; all identified findings, their severities, and their closure status are documented directly in the companion SAR.md, which functions as this system's risk register for a lab-scale system of this size.

2.1 Purpose

The purpose of this document is to report the results of the security assessment conducted against the T-Pot O&G Threat Intelligence Honeypot Lab, including findings from an OpenSCAP CIS Level 2 configuration scan, a Tenable Nessus credentialed vulnerability scan, and manual examination of network boundary, identity, encryption, and monitoring controls, and to provide risk-based recommendations for remediation or closure.

2.2 Applicable Laws, Regulations, Standards, and Guidance

NIST SP 800-53 Rev. 5, Security and Privacy Controls for Information Systems and Organizations

NIST SP 800-53A, Assessing Security and Privacy Controls in Federal Information Systems and Organizations

NIST SP 800-37 Rev. 2, Risk Management Framework for Information Systems and Organizations

2.3 Scope

The scope of the T-Pot O&G Threat Intelligence Honeypot Lab assessment is documented in the Marcus, T-Pot O&G Threat Intelligence Honeypot Lab SAP, Version 1.0, dated 08/12/2026. Deviations from the SAP are captured in Section 4.1, Deviations from the SAP. NOTE: Net-new risks identified during remediation activities are captured on the “Open” tab of the T-Pot O&G Threat Intelligence Honeypot Lab Plan of Action & Milestones (POA&M). These risks are not captured in the RET because the RET represents a point-in-time assessment.

This system runs on Microsoft Azure IaaS (East US region) rather than a CSP-managed physical data center; there is no separate physical site to enumerate. The single Azure VM and its associated network/storage resources constitute the entire infrastructure footprint (Table 2-3 below is not applicable and is left blank for this reason).

Table Executive Summary-1 Site Names and Addresses

Data Center Site Name	Address	Description Of Components

As verified by the assessor, this assessment includes the documents listed in the [FedRAMP Initial Authorization Package Checklist](#) and this SAR Appendix E - Auxiliary Documents.

2.3.1 Controls Assessed

Controls were assessed at a scope appropriate to a single-VM lab rather than a full 800-53 baseline sweep: access control, identification/authentication, boundary protection, encryption at rest and in transit, system/information integrity, audit/accountability, configuration management, and risk assessment (vulnerability scanning) families were in scope. Full per-control results are documented in the companion SAR.md/SSP.md in this system's GitHub repository.

3 System Overview

3.1 System Description

The T-Pot O&G Threat Intelligence Honeypot Lab is a single Azure IaaS Virtual Machine (Ubuntu Linux) running T-Pot HIVE edition, hosting 20+ containerized honeypot services behind an ELK stack. It deliberately exposes emulated services to the internet to capture unauthorized access attempts for security research; Conpot runs the Guardian AST template to emulate a petroleum Automatic Tank Gauge for Oil & Gas-relevant ICS/SCADA threat intelligence. See the SSP for full architecture detail.

4 Assessment Methodology

The assessment methodology is described in the T-Pot O&G Threat Intelligence Honeypot Lab SAP. The assessor performed the assessment against the SSP documented for this system. The assessment concluded on 08/12/2026.

4.1 Deviations from the SAP

None. Assessment activities were carried out as planned in the SAP, with one addition: a final Nessus credentialed re-scan was performed to verify remediation status prior to system decommissioning, which was not separately itemized in the original SAP schedule.

4.2 The SRTM

A full Security Requirements Traceability Matrix (SRTM) workbook was not built for this lab-scale system; findings are instead traced directly to their relevant NIST SP 800-53 control family in narrative form in the companion SAR.md document, which is the primary technical record for this assessment.

4.3 Consideration of Threats

As a honeypot, this system's primary operational purpose is to attract and observe real-world unauthenticated attacker activity. Findings from automated scanning were therefore evaluated against two threat models: (1) genuine risk to the management plane and underlying host, and (2) expected/by-design exposure of decoy services. Most automated findings fell into category (2); see the companion SAR.md for the full interpretive analysis distinguishing the two.

4.4 Document Results

Findings are summarized in this report and tracked to closure in the Plan of Action and Milestones (POA&M) maintained in the companion SAR.md document, which also contains full scan output interpretation, control-by-control mapping, and closure rationale for each finding.

5 Risks Known for Interconnected Systems and External Services

This system has no interconnections to production, corporate, or third-party systems. Its only external dependencies are Azure platform services (Key Vault, Log Analytics, Defender for Cloud) and outbound package repositories used at install time. One risk was identified and tracked: potential reachability of the Azure Instance Metadata Service (IMDS) from within honeypot containers, which could allow a compromised decoy service to pivot toward cloud management-plane metadata. This item was closed via system decommissioning before it could be tested live; see the companion SAR.md POA&M for full detail and the recommendation carried forward to future deployments.

Appendix A Risk Exposure Table

N/A — a formal Risk Exposure Table workbook was not built for this lab-scale system. All findings, severities, and closure rationale are documented directly in the companion SAR.md, which serves as this system's risk register.

Appendix B Security Requirements Traceability Matrix (SRTM) Workbook

N/A — see “The SRTM” in Section 3 above. Control traceability is documented in narrative form in the companion SAR.md rather than as a separate workbook.

Appendix C Vulnerability Scan Results

N/A as a set of separate scan-type appendices (Infrastructure/Database/Web/Container/Other/Unauthenticated) — this system's scanning was limited to one OpenSCAP configuration scan and one Nessus credentialed infrastructure scan against a single host, not the multi-scan-type program these appendices are structured for. Full scan data, plugin-level findings, severity breakdowns, and the honeypot-context interpretation of each finding are documented in the companion SAR.md and SSP.md in this system's GitHub repository, rather than duplicated into this template's scan-type appendix structure.

Appendix D Documentation Review Findings

N/A — no separate documentation review was performed outside of this assessment cycle itself.

Appendix E Auxiliary Documents

N/A — no auxiliary documents beyond the SSP, SAP, this SAR, and the companion Executive Report.

Appendix F Penetration Test Report

N/A — no formal penetration test was performed; see the SAP, Methodology → Penetration Test, for rationale.